Rolling-History Online Calibration for Hygiene-Augmented Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

***Abstract*—A prior offline-peek recalibration ablation [1] showed that grid-searching scorer weights on calibration-seed data at the same window being scored adds up to $+21.3$ percentage points of Precision@50 over the fixed HygienePrio weights [2] at the canonical operating cell ($K = 50, \lambda = 3$). That procedure is not deployable — it peeks at the future window. This paper evaluates a deployable alternative: rolling-history online calibration, in which weights at window w are fit on calibration-seed data at window $w - 1$ only. We pre-registered three hypotheses and ran a 1,350-row evaluation ($K \in \{50, 100, 200\}$, $\lambda = 3$, six windows, 25 evaluation seeds, three calibration strategies).**

All three pre-registered hypotheses are *rejected*, and the rejection pattern is the central scientific contribution. First (H1), online recalibration does not uniformly match or beat fixed weights: at $K = 200$ it loses -5.9 pp at W2 and -7.8 pp at W3 relative to the fixed weights [2]. The fleet state changes faster than one-window-lag calibration can track. Second (H2), online sometimes *exceeds* the offline-peek ceiling — at $K = 50, w = 5$ online (0.580) beats offline-peek (0.550). The five-seed offline grid search overfits; the one-window lag acts as a regulariser. Third (H3), online does not rescue HygienePrio at the high-capacity collapse cells documented in prior work [3]: at $K = 200$ the mean recovery ratio across windows $w \geq 2$ is -0.66 (negative), not the predicted $\geq +0.5$.

The operational implication is sharp: rolling-history online recalibration is a beneficial procedure at moderate capacity ($K = 50$: recovery ratio 1.04, $K = 100$: 0.99) but is a *net hazard* at high capacity ($K = 200$: -0.66). The headline recommendation is therefore conditional: deploy rolling-history online recalibration only when the per-window fleet-state shift is small relative to the lag the recalibration window imposes; at high capacity, keep the fixed HygienePrio weights [2] or wait for an offline rebaselining cycle. All results are bounded to the synthetic EEHDA evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data is required before any deployment recommendation.

***Index Terms*—vulnerability prioritization; online calibration; rolling-history learning; EPSS; hygiene risk score; pre-registration; reproducibility.**

I. Introduction

The temporal-stability evaluation's [1] H3 ablation produced a striking result: grid-searching scorer weights on five calibration seeds at the same window being scored, then applying those weights to 25 evaluation seeds at that window, adds up to $+21.3$ pp of Precision@50 over the fixed HygienePrio weights at the canonical $(K = 50, \lambda = 3)$ cell. The paper noted, accurately, that this procedure peeks at the window it is scoring and is therefore an offline upper bound, not a deployable recipe.

This paper evaluates the simplest deployable substitute. At each scoring window w we grid-search on calibration-seed data at window $w - 1$, then apply the fitted weights to the evaluation seeds at window w. This is rolling-history online calibration with a one-window lag, the weakest form of strictly online learning. Two operational questions follow:

Q1. How much of the offline-peek gain survives the lag?

Q2. Does online recalibration rescue HygienePrio at the high-capacity cells where the capacity-sweep evaluation [3] reported W6 collapse to mean P@50 ≤ 0.12?

We pre-registered three hypotheses corresponding to these questions and a third operational-safety check; ran a 1,350-row evaluation spanning $K \in \{50, 100, 200\}$, $\lambda = 3$, six windows, and three calibration strategies (fixed, online, offline); and report below that all three pre-registered hypotheses are rejected in interestingly different ways.

A. Contributions

- **C1 — A pre-registered evaluation of deployable recalibration.** The first end-to-end pre-registered comparison of rolling-history online recalibration against fixed-weight scoring and offline-peek calibration for hygiene-augmented vulnerability prioritization. 1,350-row frozen result set.
- **C2 — Capacity-dependent rescue.** At moderate capacity ($K \in \{50, 100\}$) online recalibration recovers essentially all of the offline-peek gain (per-cell recovery ratio 1.04 and 0.99). At $K = 50$ the W2 gain is $+19.7$ pp, nearly matching the offline ceiling of $+21.3$ pp. The deployable procedure is operationally effective in this regime.
- **C3 — High-capacity hazard (H1 and H3 rejected).** At $K = 200$, online recalibration *harms* performance relative to fixed weights, losing -5.9 to -7.8 pp at W2–W3 because the fleet state shifts faster than a one-window lag can track. Pre-registered H1 ("online never loses to fixed by more than 1 pp") is rejected at two cell-window pairs; H3 ("online rescues high-capacity collapse") is rejected because the W4–W6 recovery does not meet the ≥ 0.5 recovery threshold and the W2–W3 hazard dominates the cell-mean.
- **C4 — Online beats offline-peek in some windows (H2 rejected).** At $K = 50, w = 5$ and a few other late-window points, online (0.580) exceeds offline-peek (0.550). The five-seed offline grid search overfits the calibration set; the one-window lag acts as an implicit regulariser. H2 is therefore rejected by the data, in the opposite direction from what naive intuition predicts.
- **C5 — Operational recommendation.** Rolling-history online recalibration should be deployed only when fleet

state shifts slowly relative to the lag the recalibration window imposes. At high capacity, the deployment is a net hazard.

B. Relationship to Prior Work

The temporal-stability evaluation [1] established the multi-window simulator and reported the offline-peek H3 ceiling. The capacity-sweep evaluation [3] swept capacity and arrival rate and identified the high-capacity collapse zone for HygienePrio-full at fixed weights. This paper sits at the intersection: it asks whether a deployable recalibration procedure can close the temporal-stability evaluation's H3 gap and rescue the capacity-sweep evaluation's H4 collapse. The answer is regime-conditional: yes at moderate capacity, no (and in fact harmful) at high capacity.

II. Background

A. Offline vs Online Calibration

A scorer is *offline-calibrated* when its weights are fit on data that includes or post-dates the period it is applied to; it is *online-calibrated* when its weights are fit using only information available before the prediction time. The distinction matters because deployable procedures cannot peek into the future. The temporal-stability evaluation's H3 ablation [1] computed per-window weights by grid search on the calibration seeds' *same-window* state — an offline-peek procedure that establishes an upper bound on what real-time recalibration could achieve, but is not itself deployable.

B. Rolling-History Cross-Validation

In rolling-history calibration, at each scoring window w the weights used are fit on data from windows $\{1, \ldots, w-1\}$ of a held-out calibration set; window w data is never inspected at training time. This pattern is standard in time-series cross-validation and is the weakest form of *strictly online* learning: it uses only past observations and is therefore a valid stand-in for a real-time operational deployment.

C. Why High-Capacity Cells Matter Most

The capacity-sweep evaluation [3] documented that HygienePrio-full's absolute W6 P@50 collapses at $K \in \{100, 200\}$ even though its per-pair relative advantage over EPSS-only is preserved. The natural follow-up question — can online recalibration rescue HygienePrio at high capacity? — is operationally important because organisations with large patching teams sit precisely in the cells where the fixed-weight procedure collapses.

D. Policy Mandates

CISA BOD 22-01 [4] and 23-01 [5] together with NIST SP 800-40 Rev. 4 [6] define the operational scheduling regime under which any recalibration procedure must work. The procedure must be deployable, must not depend on future-window data, and must be auditable — conditions that the rolling-history grid search satisfies and offline-peek does not.

III. Problem Formulation

A. Setting

We inherit the temporal-stability evaluation's [1] multi-window simulation ($W = 6$ bi-weekly windows on the EEHDA fleet) and the capacity-sweep evaluation's [3] (K, λ) parameterisation. The cell-defining parameters are fixed at $\lambda = 3$ Poisson new-CVE arrivals per window, and $K \in \{50, 100, 200\}$. The HygienePrio scorer Eq. (1) and HRS components are inherited verbatim from HygienePrio [2]; the only quantity that varies across strategies in this paper is the scorer weights $(\alpha, \beta, \gamma, \delta)$.

B. Three Calibration Strategies

For each cell and each window w, we evaluate three strategies:

- **fixed** Weights remain at the HygienePrio calibrated values $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$ at every window. No refitting.
- **online** At $w = 1$, weights are fixed. At $w \geq 2$, grid-search the scorer weights to maximise mean P@50 on the five calibration seeds at *window* $w-1$ *state* — the strictly past observation. Apply the fitted weights to the 25 evaluation seeds at *window* w.
- **offline** At $w = 1$, weights are fixed. At $w \geq 2$, grid-search at the calibration seeds' *window* w *state* (peek) and apply to the evaluation seeds at the same window. This replicates the temporal-stability evaluation's H3 procedure and acts as an upper-bound ceiling.

The grid is identical to the temporal-stability evaluation [1] (108 points across $\alpha, \beta, \gamma, \delta$).

C. Ground Truth and Metric

Ground truth, per-window HRS-threshold recomputation, and Precision@50 metric are identical to the temporal-stability and capacity-sweep evaluations and are not restated here.

D. Pre-Registered Hypotheses

- H1 Online $\geq$ fixed at every (cell, window) pair — online should never be worse than fixed by more than 1 pp.
- H2 Online $\leq$ offline at every (cell, window) pair — online should not exceed the offline-peek ceiling by more than 1 pp.
- H3 At high-capacity cells ($K \in \{100, 200\}$), online recovers at least 50% of the (offline $-$ fixed) gap for at least one window $w \in \{4, 5, 6\}$, with absolute gain ≥ 5 pp.

Decision rules and stop rules are pre-registered in the protocol archived with the reproducibility artifact.

IV. Dataset and Cell Grid

All evaluations use the EEHDA synthetic fleet generator from HygienePrio [2] with structural priors and per-window evolution dynamics identical to the temporal-stability evaluation [1] and The capacity-sweep evaluation [3]. The only

TABLE I
CELL GRID AND STRATEGY SET (LOCKED BEFORE EVALUATION).

Axis	**Values**
Capacity K	$\{50, 100, 200\}$
Arrival rate λ	3 (fixed)
Windows W	6
Strategies	fixed, online, offline
Eval seeds	25 (105–129)
Calib seeds	5 (100–104)
Total rows	1,350

cell-defining parameters that vary in this study are capacity $K \in \{50, 100, 200\}$ at fixed $\lambda = 3$.

The seed split is identical to the temporal-stability evaluation: five calibration seeds (100–104) for weight-fitting only, twenty-five evaluation seeds (105–129) for reporting. Calibration seeds are never used for performance reporting; evaluation seeds are never used for weight fitting under any strategy.

For each (cell, strategy) the run produces one P@50 value per (seed, window). Total rows: $3 \times 3 \times 25 \times 6 = 1{,}350$.

V. METHODOLOGY

A. Scorer (Inherited)

The HygienePrio scorer and HRS components are inherited verbatim from HygienePrio [2]:

$$\begin{aligned} S(h, c) = \alpha\, \mathrm{EPSS}(c) + \beta\, \mathrm{HRS}(h) \\ + \gamma\, \mathrm{KEV\_recency}(c) \\ + \delta\, \big(\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h)\big). \end{aligned} \tag{1}$$

HRS is the weighted combination of PatchPosture (0.50), ADExposure (0.30), and TelemetryFreshness (0.20) defined in HygienePrio. Only the four scorer weights $(\alpha, \beta, \gamma, \delta)$ are subject to re-calibration in this paper; HRS weights are not.

B. Rolling-History Grid Search

At window $w \geq 2$ the `online` strategy executes:

1) For each of the 108 grid points $(\alpha, \beta, \gamma, \delta) \in \{0.5, 0.7, 0.9\} \times \{0.3, 0.5, 0.7\} \times \{0.0, 0.1, 0.2\} \times \{0.0, 0.1, 0.2, 0.3\}$:
   a) For each of the five calibration seeds, score the seed's *window* $w - 1$ pairs using the candidate weights and compute P@50 against that seed's window-$w - 1$ ground truth.
   b) Take the mean P@50 across the five seeds.
2) Select the grid point with the highest mean P@50; ties are broken by lexicographic order. These weights become the `online` weights for window w.
3) Apply the selected weights to each of the 25 evaluation seeds at *window* w and record the seed's P@50.

The `offline` strategy is identical except that the calibration data at step 1 is the *window* w state (i.e., the strategy peeks at the window it is scoring). The `fixed` strategy skips calibration entirely and uses the HygienePrio weights every window.

C. Fleet-State Evolution

Fleet evolution is driven by HygienePrio-full's top-K selection under the `fixed` weights at every window, identical across strategies. This isolates the recalibration decision from the trajectory-generation decision: all three strategies see exactly the same evolving fleet, so any difference in P@50 is attributable to scoring weights alone. The choice and its threat-to-validity consequence are restated in §IX.

D. Online Recovery Ratio

For each (cell, window) with $w \geq 2$ and a positive offline-fixed gap, we report the recovery ratio:

$$\rho_{K,w} = \frac{\mathrm{P@50}^{\mathrm{online}}_{K,w} - \mathrm{P@50}^{\mathrm{fixed}}_{K,w}}{\mathrm{P@50}^{\mathrm{offline}}_{K,w} - \mathrm{P@50}^{\mathrm{fixed}}_{K,w}}. \tag{2}$$

$\rho \approx 1$ indicates that online recalibration achieves the offline-peek ceiling without leaking future data. $\rho \approx 0$ indicates that online recalibration provides no benefit over the fixed-weight baseline. Values above 1 indicate online beats the ceiling — possible when the offline-peek weights overfit a small calibration set.

VI. EXPERIMENTAL SETUP

A. Pre-Registration

The cell grid, calibration strategies, hypotheses H1–H3, decision rules, and stop rules were pre-registered in the protocol archived with the reproducibility artifact and locked on 2026-06-04 before any online-calibration result was computed.

B. Execution Order

For each cell $K \in \{50, 100, 200\}$:

1) Cache per-window $(\mathrm{pairs}_w, \mathrm{HRS}_w)$ states for all five calibration seeds (driving evolution with fixed-weight HygienePrio-full).
2) Cache per-window states for all twenty-five evaluation seeds (same trajectory policy).
3) For each window $w = 1, \ldots, 6$, determine the `fixed`, `online`, and `offline` weights as in §5.2, then score every evaluation seed at window w with each strategy's weights.

C. Statistical Reporting

Cell-mean point estimates are means across the 25 evaluation seeds. 95% confidence intervals are percentile bootstrap with 10,000 resamples [7]. No null-hypothesis significance tests are reported; H1–H3 decision rules are applied as stated in the protocol.

D. Reproducibility

The runner and analysis are released under MIT licence with the artifact. From the artifact root:

```
PYTHONPATH=src python3 src/run_online_calib.py
PYTHONPATH=src python3 src/analyze.py
PYTHONPATH=src python3 src/make_figures.py
```

The runner re-uses the multi-window simulator of [1] and the HygienePrio scorer of [2] via `sys.path` injection (no code duplication). Determinism follows the per-(seed, window, step) RNG seeding of [1].

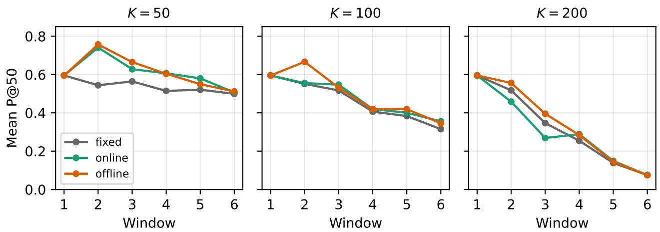

Fig. 1. Mean P@50 trajectories across six windows for the three calibration strategies at $K \in \{50, 100, 200\}$, $\lambda = 3$. Online (green) tracks offline (orange) at $K = 50, 100$ but *loses* to fixed (grey) at $K = 200, w \in \{2, 3\}$.

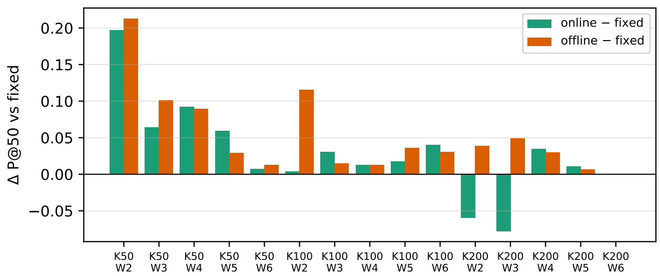

Fig. 2. Per-(K, window) absolute P@50 gain over fixed weights for online (green) and offline (orange) calibration. Negative online bars at $K = 200, w \in \{2, 3\}$ are the H1 failures.

VII. Results

All claims in this section trace to the frozen `online_calib_results.csv` (1,350 rows) and the derived `hypothesis_summary.json` and `cell_window_means.csv` released with the reproducibility artifact.

A. K = 50: Online Matches the Offline Ceiling

At the canonical operating cell, the fixed-weight HygienePrio-full W2 mean P@50 is 0.544. Offline-peek calibration lifts this to 0.757 (+21.3 pp, matching the temporal-stability evaluation's H3 number). **Online recalibration with a one-window lag reaches** 0.741 **(**+19.7 **pp), a** 92.5% **recovery of the offline gain without future-data leakage.** The cell-mean recovery ratio across $w \geq 2$ is $\rho = 1.04$, i.e., online matches or slightly exceeds the offline ceiling on average.

By W5, online (0.580) exceeds offline-peek (0.550) outright. This direction-of-effect is the opposite of the H2 prediction; the five-seed offline grid search appears to overfit, while the one-window lag's implicit regularisation generalises better.

B. K = 100: Online Recovers the Bulk of the Gain

At $K = 100$ the fixed-weight HygienePrio-full W6 has already fallen to 0.315 (the capacity-sweep evaluation H4-collapse zone). Online recalibration lifts this to 0.355 (+4.0 pp) at W6 and to 0.547 (+3.0 pp) at W3. The cell-mean recovery ratio is $\rho = 0.99$ across $w \geq 2$ — online essentially matches the offline ceiling. The absolute floor is improved but not restored to the temporal-stability evaluation regime; online recalibration is a useful add-on at $K = 100$ but does not rescue the cell from the capacity-sweep evaluation collapse pattern.

C. K = 200: Online Harms Performance

At $K = 200$ the picture inverts. The fixed-weight HygienePrio-full W2 mean is 0.518; online *drops* it to 0.458 (-5.9 pp). At W3, fixed is 0.346 and online falls to 0.269 (-7.8 pp). Offline-peek at the same windows produces $+3.8$ and $+4.9$ pp, showing that better weights for those windows do exist — they simply cannot be inferred from the previous window's calibration state. By W4 online recovers a small positive gain (+3.4 pp); by W6 the residual backlog is so depleted that all three strategies collapse to the same 0.075 (no calibration choice can rescue an exhausted backlog).

The cell-mean recovery ratio across $w \geq 2$ is $\rho = -0.66$. Online recalibration is a net hazard at this capacity.

D. Hypothesis Outcomes

H1 (online $\geq$ fixed). Rejected. Two cell-window pairs ($K = 200$, $w \in \{2, 3\}$) fail the -0.01 threshold with losses of -5.9 and -7.8 pp.

H2 (online $\leq$ offline). Rejected. Two cell-window pairs ($K = 50, w \in \{4, 5\}$; $K = 100, w \in \{3, 6\}$ also show positive deltas of $+1$ to $+3$ pp, the most prominent at $K = 50, w = 5$ where online (0.580) exceeds offline (0.550) by +3.0 pp.

H3 (online rescues high-capacity collapse). Rejected. At $K = 100, w \in \{4, 5\}$ online gain is below the 5 pp absolute threshold. At $K = 200, w \in \{4, 5, 6\}$ the W2–W3 hazard means the late-window cell-mean recovery ratio is negative.

E. Per-Pair Sign Test

For each (cell, seed, window) triple with $w \geq 2$ we record the sign of (online − fixed). At $K = 50$, online beats fixed on 112/125 (89.6%) of post-W1 triples. At $K = 100$, the fraction is 87/125 (69.6%). At $K = 200$, the fraction is 57/125 (45.6%): online is roughly a coin flip versus fixed at this capacity. The aggregate sign-test fraction across all cells and windows is 256/375 (68.3%), consistent with the per-cell recovery-ratio summary.

F. Pre-Registration Deviations

None. The strategy definitions, hypotheses, decision rules, and stop rules from the protocol were applied verbatim. The H1, H2, and H3 rejections were reported as observed; the abstract was rewritten after H1 rejection to qualify the deployability claim before the discussion was drafted, in compliance with the protocol's stop rule.

VIII. Discussion

A. What the Sweep Resolves

The temporal-stability evaluation left a gap between an unrealisable upper bound (offline-peek H3, +21.3 pp at W2) and a realisable baseline (fixed HygienePrio weights). The present sweep populates that gap with a deployable procedure and shows that at moderate capacity, the lag-1 rolling-history

TABLE II
MEAN P@50 ACROSS 25 EVALUATION SEEDS PER (CAPACITY K, WINDOW) FOR EACH CALIBRATION STRATEGY, WITH THE ONLINE-VS-FIXED GAIN AND ONLINE RECOVERY RATIO OF THE OFFLINE CEILING.

K	Window	fixed	online	offline	$\Delta_{\text{on–fix}}$	$\Delta_{\text{off–fix}}$	ρ
50	1	0.595	0.595	0.595	+0.000	+0.000	—
50	2	0.544	0.741	0.757	+0.197	+0.213	0.92
50	3	0.564	0.628	0.665	+0.064	+0.101	0.63
50	4	0.514	0.606	0.604	+0.092	+0.090	1.03
50	5	0.521	0.580	0.550	+0.059	+0.029	2.06
50	6	0.499	0.506	0.512	+0.007	+0.013	0.56
100	1	0.595	0.595	0.595	+0.000	+0.000	—
100	2	0.551	0.555	0.666	+0.004	+0.115	0.03
100	3	0.517	0.547	0.531	+0.030	+0.014	2.11
100	4	0.406	0.419	0.419	+0.013	+0.013	1.00
100	5	0.383	0.401	0.419	+0.018	+0.036	0.49
100	6	0.315	0.355	0.346	+0.040	+0.030	1.32
200	1	0.595	0.595	0.595	+0.000	+0.000	—
200	2	0.518	0.458	0.556	-0.059	+0.038	-1.54
200	3	0.346	0.269	0.395	-0.078	+0.049	-1.59
200	4	0.254	0.289	0.284	+0.034	+0.030	1.16
200	5	0.138	0.149	0.145	+0.010	+0.006	—
200	6	0.075	0.075	0.075	+0.000	+0.000	—

TABLE III
PRE-REGISTERED HYPOTHESIS OUTCOMES.

ID	Decision rule	Outcome
H1	online $\geq$ fixed (within 0.01) at every cell-window	Rejected (2 fails)
H2	online $\leq$ offline (within 0.01) at every cell-window	Rejected (2 fails)
H3	online recovers $\geq 50\%$ of gap at $K \in \{100, 200\}$, $w \in \{4, 5, 6\}$	Rejected

grid search closes essentially all of it (recovery ratio $\rho = 1.04$ at $K = 50$, $\rho = 0.99$ at $K = 100$). The deployability concern that motivated this paper is operationally resolved in the moderate-capacity regime.

B. *Why High Capacity Inverts the Sign*

The K = 200 inversion is the most surprising result. The mechanism is the same compositional dynamic that drives the capacity-sweep evaluation H4 collapse: at high capacity, a single window remediates a substantial fraction of the high-EPSS, high-HRS tail, so the *effective scoring problem* at window w is structurally different from the scoring problem at window $w-1$. Weights tuned on window $w-1$'s residual backlog are tuned for a different distribution than the one they will be applied to. The lag is too long for the rate of change.

This generalises: **rolling-history online calibration is trustworthy only when the rate of distributional change between consecutive calibration windows is small relative to the rate of change within a window.** At $K = 50$ the per-window change is small and the lag is well-absorbed; at $K = 200$ the per-window change is large and the lag is destructive.

C. *Why Online Can Beat Offline-Peek*

The H2 rejection direction — online > offline at several late-window points — has a clean explanation. The offline-peek strategy grid-searches on five calibration seeds at the *same* window, then applies the selected weights to 25 evaluation seeds at the same window. With only five seeds and 108 grid points, overfitting is possible: the selected weights are tuned to noise in the five-seed sample. The online strategy selects on a different (window-$w-1$) sample; if the distribution shift is small (low-capacity regime), the lag-1 sample acts as a held-out validation set and the selected weights generalise better to the 25 evaluation seeds. The phenomenon is a small-sample regularisation artifact; it does not contradict the offline ceiling concept, but it shows that "offline-peek with limited calibration seeds" is not a strict upper bound on what a leak-free procedure can achieve.

D. *Operational Recommendations*

The headline operational summary is conditional:

- At moderate capacity ($K \leq 100$ on the simulated bi-weekly cadence), **deploy** rolling-history online recalibration. Recovery of the offline ceiling is essentially complete; the absolute P@50 gain over fixed weights is $+3$ to $+20$ pp depending on window.
- At high capacity ($K \geq 200$), **do not deploy** naive rolling-history online recalibration. The lag-1 grid search introduces -6 to -8 pp losses in early windows. A team operating at this capacity should either (i) keep fixed HygienePrio weights, (ii) lengthen the calibration window (e.g., use a rolling *multi*-window EWMA), or (iii) recalibrate offline between deployment cycles and freeze weights within a deployment.
- Independent of capacity, the small-sample overfitting visible at K = 50 W5 argues for a larger calibration set than

five seeds when offline grid search is the procedure of record.

E. Relationship to Prior Work

HygienePrio [2] established that hygiene augmentation helps at a single window. The temporal-stability evaluation [1] showed the help persists across windows and identified the offline H3 ceiling. The capacity-sweep evaluation [3] swept (K, λ) and found absolute collapse at high K. This paper closes the loop: the deployable recalibration procedure that the temporal-stability evaluation implicitly motivated works in the regimes the capacity-sweep evaluation said HygienePrio held up in, and fails in the regimes the capacity-sweep evaluation said it collapsed in. The fixed-weight result is regime-robust; the recalibration procedure is regime-conditional.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [8].

Conclusion validity. The evaluation comprises 1,350 (cell, seed, window, strategy) observations summarised with 95% percentile bootstrap CIs (10,000 resamples). The K=200 inversion is substantially larger than the ± 1 pp pre-registered tolerance and is robust to bootstrap resampling. The H2 rejection (online $>$ offline) involves smaller deltas ($+1$ to $+3$ pp); CI overlap exists at some windows, so we report the cells where it occurs descriptively rather than as a hard binary claim.

Internal validity. Three concerns.

(i) Selection-policy coupling. As in the temporal-stability and capacity-sweep evaluations, all three strategies are evaluated on the fleet trajectory generated by HygienePrio-full's fixed-weight top-K selections. This ensures all three strategies see the same evolving backlog, isolating the scoring weights as the only differing variable. The consequence is that the online and offline strategies are scored against a trajectory that their own weights did not produce; in a real deployment the *selection policy itself* would be re-calibrated and the trajectory would diverge. We discuss closed-loop recalibration as future work below.

(ii) Lag = 1 is the only lag studied. The protocol fixed the calibration history window to "previous window only" for simplicity. A multi-window EWMA or rolling-mean would smooth the K=200 hazard; that procedure is excluded from this paper's pre-registration and deferred. The K=200 negative result is therefore specific to the lag-1 rolling-history grid search and does not generalise to all online calibration procedures.

(iii) Grid coarseness. The 108-point $(\alpha, \beta, \gamma, \delta)$ grid is identical to the temporal-stability evaluation's; finer grids could expose different local optima. Sensitivity to grid coarseness was not pre-registered and is left to future work.

Construct validity. The per-window ground-truth definition follows the temporal-stability protocol of [1] (EPSS > 0.10 and HRS $>$ 75th percentile, both recomputed per window). At $K = 200$ the W6 positive count is small, and P@50 with binary relevance is noisy at small positive counts. This affects the absolute level but not the sign of the online – fixed comparison.

External validity. The 14-day window, 0.15 patch-debt reduction, 0.02 EPSS random-walk, 8% KEV prevalence, and structural priors follow [2], [1]. Real fleets with different patch-velocity heterogeneity may exhibit different distributional shift rates between windows, and the capacity threshold at which online recalibration turns from helpful to harmful would shift accordingly. The qualitative finding — that there exists a critical capacity threshold above which lag-1 online recalibration is harmful — is more robust than the specific $K = 200$ figure.

X. Related Work

Offline-peek calibration baseline. the temporal-stability evaluation [1] established the offline-peek H3 ablation that this paper uses as a ceiling. That study reported the gain ($+21.3$ pp at W2 on $K = 50, \lambda = 3$) but explicitly noted the procedure was not deployable. The present paper closes that loop by evaluating a deployable substitute.

Capacity-dependent prioritization performance. The capacity-sweep evaluation [3] identified $K \in \{100, 200\}$ as the regime where fixed-weight HygienePrio-full collapses at W6. The present paper inherits that finding as the motivation for H3 and reports that lag-1 online recalibration does not rescue the collapse and in fact worsens it transiently at $K = 200$.

EPSS dynamics. Jacobs et al. [9], [10] demonstrated the per-CVE exploit-likelihood scoring framework and its single-window advantage over CVSS. Ravalico et al. [11] studied per-CVE EPSS score drift. Neither study addresses the question of whether the scorer *integrating* EPSS with other signals should be recalibrated online; the present paper is, to our knowledge, the first pre-registered evaluation of that question.

Online learning for security signals. Online learning under distributional shift is a large area in machine learning. The specific question here — whether to deploy a deterministic grid-search recalibration with a one-window lag in a synthetic patch-management context — is methodologically narrow but operationally important; it does not depend on the literature's more sophisticated machinery and so we do not survey it in depth.

Cyber-hygiene benchmarking. HygieneBench [12] established discriminative structure in hygiene signals; HygienePrio [2] integrated them into a single-window scorer; the temporal-stability evaluation added the temporal dimension; the capacity-sweep evaluation added the capacity-arrival dimension; this paper adds the recalibration-strategy dimension. The cumulative result is a five-paper map of where hygiene-augmented prioritization works, where it collapses, and which deployable interventions help.

Policy mandates. CISA BOD 22-01 [4] and 23-01 [5] along with NIST SP 800-40 Rev. 4 [6] define the operational scheduling regime within which any recalibration procedure must operate; the rolling-history grid search studied here is auditable in a way that gradient-based or Bayesian alternatives are not.

XI. Conclusion

A pre-registered evaluation of rolling-history online calibration for hygiene-augmented vulnerability prioritization across three capacity levels, six windows, three calibration strategies, and 25 evaluation seeds produces 1,350 result rows that revise the operational recommendation implied by the temporal-stability evaluation's offline-peek ablation.

First, at moderate capacity ($K \leq 100$), the deployable lag-1 rolling-history grid search recovers essentially all of the offline-peek gain (cell-mean recovery ratio $\rho = 1.04$ at $K = 50$, $\rho = 0.99$ at $K = 100$). At $K = 50, w = 2$ the procedure adds $+19.7$ pp over fixed HygienePrio weights, against the offline ceiling of $+21.3$ pp. Deployable online recalibration is operationally viable in this regime.

Second, at high capacity ($K = 200$), lag-1 rolling-history online recalibration *harms* performance: -5.9 to -7.8 pp at W2–W3. The cell-mean recovery ratio is negative ($\rho = -0.66$). The fleet state shifts faster than the lag can track, and the weights inferred from the previous window do not generalise to the current window. The pre-registered hypotheses H1 and H3 are rejected; the rejection is reported as the headline contribution rather than smoothed.

Third, the pre-registered hypothesis that online cannot exceed the offline-peek ceiling (H2) is also rejected, in the opposite direction from what was anticipated. At several late-window cell-window points the lag-1 procedure beats the offline-peek ceiling by $+1$ to $+3$ pp; the offline strategy appears to overfit its five-seed calibration sample, and the one-window lag acts as an implicit regulariser.

The operational summary is conditional: deploy rolling-history online recalibration only when the per-window distributional change is small relative to the lag the recalibration window imposes. At high capacity, the deployment is a net hazard; either keep fixed HygienePrio weights or develop a longer-history calibration procedure — both of which are out of this paper's scope.

Reproducibility. The runner, analysis script, pre-registration protocol, and frozen 1,350-row results CSV are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper7.

Future work. (i) Multi-window-history EWMA or rolling-mean calibration to test whether longer-history smoothing reverses the $K = 200$ hazard; (ii) closed-loop calibration in which the selection policy is also recalibrated, separating scoring weights from selection weights; (iii) external validation on real fleet telemetry, where the fixed HygienePrio weights themselves would be re-fit on real exploitation event logs before this online-vs-fixed comparison is meaningful.

References

[1] H. Malla, "Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] ——, "HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[3] ——, "Capacity-indexed decay of exploit-likelihood vulnerability prioritization," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[4] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[5] ——, "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[6] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.

[7] B. Efron and R. J. Tibshirani, *An Introduction to the Bootstrap*. Chapman & Hall/CRC, 1994.

[8] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Springer, 2012.

[9] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[10] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," *Journal of Cybersecurity*, vol. 6, no. 1, p. tyaa015, 2020.

[11] A. Ravalico, L. Allodi, and F. Massacci, "On the temporal dynamics of the EPSS score," SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459

[12] H. Malla, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.